

Cadre de gestion des risques opérationnels et de réponse aux incidents

9567-0048 Québec inc. — 60sec-Paiement

Pièce jointe à la demande d'enregistrement d'un fournisseur de services de paiement

Banque du Canada — Loi sur les activités associées aux paiements de détail — section 11

Demandeur : 9567-0048 Québec inc., NEQ 1182124850, 102 chemin Miltimore, Sutton (Québec) J0E 2P0

Nom commercial : 60sec-Paiement

Personne désignée : Yves Perron, président-directeur général — y@le102.ca — 514-885-9351

Cadre dirigeant responsable du présent cadre : Yves Perron, président-directeur général

Date prévue de lancement : 1^{er} avril 2027

Version : 1.0 — 8 septembre 2026

Le présent cadre est établi en application de l'article 5 du Règlement sur les activités associées aux paiements de détail. Il énonce les objectifs d'intégrité, de confidentialité et de disponibilité que le demandeur se donne, les risques qu'il recense, les mesures qu'il applique pour les atténuer, la manière dont il détecte un incident et y répond, et les examens et mises à l'essai auxquels il soumet le tout. Il se lit avec la description des services jointe à la question 6.1 et les diagrammes joints à la question 6.3.

1. Objet, portée et proportionnalité

Le présent cadre couvre l'ensemble des activités associées aux paiements de détail du demandeur : les encaissements par débit préautorisé, les décaissements par virement de crédit, les virements Interac, la détention des fonds des utilisateurs finaux dans le compte en fiducie, ainsi que les systèmes, les données et les processus qui les portent. Il couvre également les fonctions confiées à des tiers.

La proportionnalité, telle que le demandeur l'entend

Le paragraphe 5(2) du Règlement veut que chaque aspect du cadre soit proportionné aux répercussions possibles d'une défaillance, compte tenu de l'ubiquité du fournisseur et de son interconnexion. Le demandeur situe ces deux grandeurs comme suit, à partir des volumes déclarés à la section 11 de la demande.

Grandeur	Valeur, an 1	Ce que le demandeur en tire
Utilisateurs finaux détenant un solde	120 abonnés au 31 mars 2028	Population restreinte et identifiée : chaque abonné peut être joint individuellement en cas d'incident.
Opérations traitées	41 300 · 15 860 000 \$	Volume modeste ; une interruption d'une journée ouvrable touche environ 165 opérations.
Fonds détenus, valeur moyenne	≈ 210 000 \$	C'est le montant réellement exposé à une défaillance d'intégrité, non le volume annuel.
Fonds détenus, valeur de pointe	≈ 480 000 \$	Dimensionne le pire cas retenu pour les essais fondés sur des scénarios.
Interconnexion	Une institution parraine, un partenaire de virement, un hébergeur	Faible nombre de dépendances, mais aucune redondance : la défaillance d'un seul tiers arrête le service.
Ubiquité	Aucune fonction d'infrastructure partagée	Le demandeur n'est le point de passage d'aucun autre fournisseur ; une défaillance ne se propage pas au système de paiement.

La conclusion que le demandeur en tire. L'ubiquité est faible et l'interconnexion est concentrée. Le cadre porte donc son effort sur deux points plutôt que de s'étendre uniformément : **l'intégrité du grand livre et du compte en fiducie**, parce qu'une erreur y est irréversible pour l'utilisateur final, et **la dépendance aux tiers**, parce qu'aucun d'eux n'est doublé. La disponibilité vient ensuite : un traitement par lots reporté d'une journée ouvrable est une gêne, non une perte.

2. Objectifs, cibles de fiabilité et indicateurs

Alinéas 5(1)a) et 5(1)b) du Règlement.

Objectif	Cible	Indicateur	Fréquence
Intégrité	Aucun écart entre le compte de fiducie du grand livre et le relevé de l'institution parraine	Écart de rapprochement, en cents ; nombre d'écarts non résolus à la clôture du jour	Quotidienne
Intégrité	Invariant du grand livre vérifié sans exception voir la note 1 de l'annexe	Nombre de vérifications de l'invariant du grand livre en échec	À chaque écriture
Intégrité	Aucun fichier de la norme 005 rejeté à l'entrée pour cause de format fichiers de virements de débit et de crédit déposés auprès de l'institution parraine — voir la note 5 de l'annexe	Taux de rejet de fichier ; taux de rejet d'article	À chaque dépôt
Confidentialité	Aucun accès non autorisé aux données d'un abonné ou d'une contrepartie	Nombre d'accès refusés anormaux ; nombre d'incidents de confidentialité voir la note 6 de l'annexe	Continue
Disponibilité	Portail et interface disponibles 99,5 % des heures ouvrables	Minutes d'indisponibilité, heures ouvrables	Mensuelle
Disponibilité	Aucun lot manqué en raison de l'heure de tombée de l'institution parraine lots de virements de débit et de crédit du jour, trajets A et B ; le virement Interac ne se traite pas en lot — voir la note 7 de l'annexe	Nombre de lots transmis après l'heure de tombée	Quotidienne
Rétablissement	Reprise du service en 4 heures ouvrables ; perte de données nulle	Délai de reprise constaté ; point de reprise constaté	À chaque essai et à chaque incident
Détection	Tout incident détecté en 60 minutes ; qualification en 4 heures voir la note 11 de l'annexe	Délai entre survenance et détection ; délai entre détection et qualification	À chaque incident

Cibles proposées, à confirmer avant le dépôt et à revoir avec l'institution financière parraine, dont l'entente fixera notamment les heures de tombée et les délais de transmission.

3. Rôles, responsabilités et ressources

Alinéas 5(1)c) et 5(1)d), paragraphes 5(5) et 5(6), articles 6 et 7 du Règlement.

Rôle	Responsabilité au regard du présent cadre
Cadre dirigeant président-directeur général	Établit, met en œuvre et maintient le cadre. Approuve le cadre et chacune de ses modifications importantes. Reçoit les résultats de l'examen annuel, des mises à l'essai et de l'examen indépendant. Décide de la qualification d'un incident et autorise les notifications.
Conseil d'administration	Approuve le cadre au moins une fois l'an et après chaque modification importante. Le conseil est actuellement composé d'un seul administrateur, qui est aussi le cadre dirigeant — voir l'encadré ci-dessous.
Exploitation de la plateforme	Prépare et approuve les lots, surveille les indicateurs, exécute le rapprochement quotidien, ouvre et documente les incidents.
Ingénierie	Applique les correctifs, tient la configuration, exécute les essais techniques et les remises en service.
Agent de conformité	Programme de lutte contre le recyclage des produits de la criminalité, joint à la section 16 de la demande. Externe aux opérations ; il n'approuve aucun lot.
Ressource indépendante	Réalise l'examen indépendant prévu à l'article 10 du Règlement. À nommer.

Cumul des rôles, et ce que le demandeur fait pour le corriger. À la date de la demande, le demandeur est une entreprise à administrateur unique : la même personne est cadre dirigeant, administrateur et responsable de l'exploitation. Le demandeur ne présente pas ce cumul comme neutre. Trois mesures le compensent, et elles sont vérifiables : la **double approbation des lots**, qui exige une seconde personne avant toute transmission et qui ne peut être levée par le cadre dirigeant ; l'**examen indépendant** de l'article 10, confié à une ressource externe et compétente ; et le caractère **immuable et rapproché quotidiennement** du grand livre, qui rend une intervention unilatérale visible le lendemain. Le recrutement d'une seconde personne habilitée à approuver les lots est une condition d'activation de la fonction de paiement, et non un objectif ultérieur.

Ressources

- **Humaines** — au lancement, le cadre dirigeant, une personne d'exploitation habilitée à la seconde approbation, et une ressource d'ingénierie. La formation au présent cadre et au programme de conformité est préalable à l'octroi de tout accès de production.
- **Financières** — une provision d'exploitation couvrant douze mois de charges fixes, indépendante des fonds des utilisateurs finaux et jamais prélevée sur le compte en fiducie, est maintenue pour financer une réponse à un incident, un examen indépendant ou une remise en service.
- **Accès en cas d'incident** — les coordonnées de l'institution parraine, du partenaire de virement, de l'hébergeur et de la ressource indépendante sont tenues hors ligne, avec les procédures de dégradation, de sorte qu'une panne des systèmes n'empêche pas d'y accéder.

4. Recensement des actifs et des processus opérationnels

Alinéa 5(1)e) du Règlement. Sensibilité : effet d'une divulgation. Importance : effet d'une indisponibilité ou d'une altération.

Actif ou processus	Sensibilité	Importance	Motif
Grand livre	Élevée	Critique	Établit la part de chaque abonné dans le compte en fiducie. Une altération est une perte de fonds pour un utilisateur final.
Compte en fiducie et accès bancaire	Élevée	Critique	Détient les fonds des utilisateurs finaux. Tout accès est réputé sensible.
Production et transmission des fichiers 005 voir la note 5 de l'annexe	Élevée	Critique	Porte des coordonnées bancaires de tiers et déclenche des mouvements irréversibles.
Ententes de débit préautorisé et preuves	Élevée	Élevée	Fondent la licéité de chaque prélèvement et la défense en cas de contestation.
Données des contreparties coordonnées bancaires, renseignements personnels	Élevée	Élevée	Renseignements personnels de tiers qui ne sont pas clients du demandeur.
Fiches d'abonné et vérifications	Élevée	Moyenne	Contiennent les résultats de vérification d'entreprise et de propriété effective.
Portail et interface de programmation	Moyenne	Élevée	Point d'entrée des instructions ; leur indisponibilité suspend le service sans altérer les fonds. voir la note 8 de l'annexe
Clés d'API, secrets et journaux d'accès	Élevée	Élevée	Leur compromission permettrait d'initier des opérations au nom d'un abonné.
Journaux et piste d'audit	Moyenne	Élevée	Seul moyen de reconstituer un incident et d'en établir la cause première.
Hébergement infonuagique — externalisé	Élevée	Critique	Porte l'ensemble des systèmes ci-dessus. Résidence des données au Canada exigée par entente.
Portail partenaire	Moyenne	Moyenne	Provisionnement d'abonnés par un tiers, sans accès aux fonds ni au grand livre.

5. Recensement des risques opérationnels

Alinéa 5(1)f) du Règlement. Les onze catégories prévues sont reprises telles quelles.

Catégorie	Risque principal chez le demandeur	Atténuation dominante
Continuité des activités et résilience	Indisponibilité de l'hébergeur ou de l'institution parraine un jour de dépôt.	Procédure de dégradation, report du lot au jour ouvrable suivant, avis aux abonnés touchés.
Cybersécurité	Compromission d'une clé d'API ou d'un compte d'administration permettant d'initier des opérations.	Authentification à deux facteurs, moindre privilège, rotation des clés, double approbation des lots. voir la note 2 de l'annexe
Fraude	Prélèvement sans entente valide, ou abonné qui détourne la plateforme pour encaisser sans droit. voir la note 3 de l'annexe	Vérification d'entreprise préalable, droit d'audit sur les ententes, plafonds par abonné, surveillance du taux de retour.
Gestion des données et des renseignements	Divulgence de coordonnées bancaires de contreparties.	Chiffrement au repos et en transit, cloisonnement par locataire, journalisation des accès. voir la note 4 de l'annexe
Technologies de l'information	Défaut logiciel produisant un fichier 005 non conforme ou une écriture erronée. voir la note 5 de l'annexe	Cycle de développement contrôlé, jeu d'essais de conformité au format, vérification de l'invariant du grand livre à chaque écriture.
Ressources humaines	Départ ou indisponibilité de l'unique personne connaissant une procédure.	Documentation opératoire, suppléance nommée, accès de secours scellés.
Conception et mise en œuvre de processus	Rapprochement omis ou retour non imputé, laissant un écart s'installer.	Rapprochement quotidien obligatoire avec blocage de la clôture, file des retours non rapprochés.
Conception et mise en œuvre des produits	Plafond ou délai de retenue mal calibré exposant le demandeur aux retours.	Revue des plafonds et de la réserve à l'activation, puis selon l'historique de retours.
Gestion du changement	Mise en production altérant le comportement d'un trajet de fonds.	Essais préalables à toute modification importante, remise en service documentée, approbation du cadre dirigeant.
Sécurité physique des personnes et des actifs	Perte ou vol d'un poste de travail donnant accès aux systèmes.	Chiffrement intégral des postes, effacement à distance, aucun stockage local de données de production.
Tiers fournisseurs, mandataires, entités affiliées	Défaillance ou résiliation par l'institution parraine, le partenaire de virement ou l'hébergeur.	Ententes écrites, évaluation régulière, plans de réponse coordonnés, veille sur une solution de rechange.

6. Les mesures de protection

Alinéa 5(1)g) du Règlement. Les huit domaines prévus pour les technologies de l'information et la cybersécurité sont repris tels quels.

Domaine	Mesure appliquée
Gestion des accès y compris l'accès physique	Comptes nominatifs, moindre privilège, authentification à deux facteurs obligatoire sur tout accès de production. Séparation des droits de préparation et d'approbation d'un lot. Revue trimestrielle des accès. Aucun local physique ne porte de données de production. voir la note 9 de l'annexe
Gestion des vulnérabilités et correctifs	Veille sur les composants employés, application des correctifs critiques dans les délais fixés par leur gravité, suivi des dépendances applicatives.
Logiciels de sécurité	Protection contre les programmes malveillants sur les postes de travail et les serveurs, mise à jour automatique.
Configuration sécurisée des appareils	Configuration de référence documentée, chiffrement intégral des postes, verrouillage automatique, effacement à distance.
Sécurité des réseaux	Chiffrement en transit, restriction des accès administratifs par adresse, cloisonnement des environnements de développement et de production. voir la note 10 de l'annexe
Services infonuagiques et externalisés	Hébergement au Canada sous entente écrite prévoyant la résidence des données, la journalisation et la notification des incidents. Sauvegardes chiffrées, restauration mise à l'essai.
Supports sécurisés	Aucun support amovible en production. Les exports sont chiffrés, horodatés et journalisés.
Cycle de développement sécurisé	Revue de code par une seconde personne, jeu d'essais automatisé sur le format 005 et sur l'invariant du grand livre, environnements séparés, aucune donnée de production en développement. voir la note 5 de l'annexe

Les mesures propres aux fonds et au grand livre

- **Séparation** — les fonds des utilisateurs finaux sont dans un compte en fiducie à vocation unique, distinct des fonds propres, sans découvert autorisé.
- **Écriture en partie double et immuable** — aucune écriture n'est modifiée ni effacée ; une correction est une contre-passation.
- **Invariant vérifié en continu** — la somme des obligations envers les abonnés est confrontée au compte de fiducie à chaque écriture.
- **Rapprochement quotidien** — le compte de fiducie du grand livre est confronté au relevé de l'institution parraine ; un écart bloque la clôture du jour.
- **Plafonds** — 25 000 \$ par opération, 250 000 \$ par fichier, 500 000 \$ par jour pour la plateforme, 50 000 \$ par jour et par abonné par défaut. Un dépassement annule le lot.

- **Retenue et réserve** — cinq jours ouvrables de retenue et une réserve de 10 % du volume de débits sur trente jours absorbent les retours.

7. Détection et contrôle continu

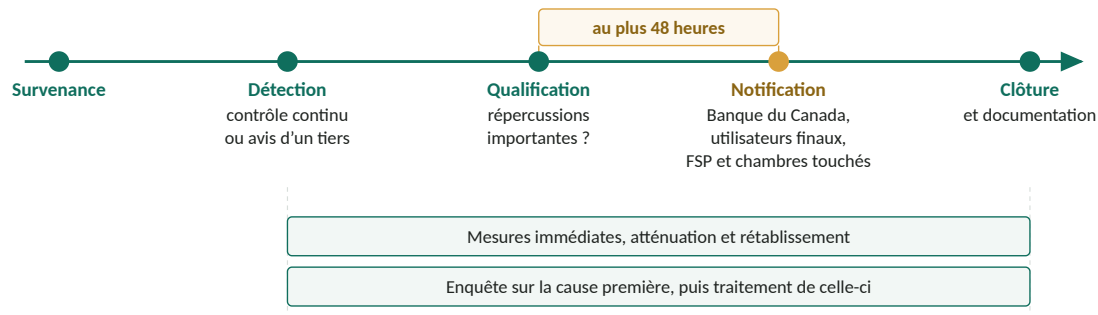
Alinéas 5(1)h) et 5(1)j) du Règlement.

Signal surveillé	Seuil interne	Suite donnée
Écart de rapprochement	Tout écart, dès un cent	Incident ouvert d'office ; clôture du jour bloquée ; enquête immédiate.
Vérification de l'invariant du grand livre en échec	Une seule occurrence	Suspension des transmissions ; qualification en 4 heures. voir la note 11 de l'annexe
Rejet d'un fichier à l'entrée	Une seule occurrence	Correction et redépôt le jour même si l'heure de tombée le permet ; avis aux abonnés touchés à défaut.
Taux de retour d'un abonné voir la note 12 de l'annexe	Au-delà du seuil porté à sa fiche	Révision du plafond, de la réserve, et examen des ententes de débit préautorisé.
Indisponibilité du portail ou de l'interface	15 minutes continues	Incident ouvert ; avis aux abonnés si l'indisponibilité dépasse une heure ouvrable.
Accès refusés anormaux, connexions inhabituelles	Selon le profil surveillé	Vérification, et suspension de la clé ou du compte en cause au besoin.
Avis de sécurité d'un tiers voir la note 13 de l'annexe	Tout avis touchant un composant employé	Évaluation de l'exposition dans le délai fixé par la gravité.

Le contrôle continu s'appuie sur l'enregistrement et la surveillance des journaux, la détection des programmes malveillants, les défenses du réseau, la détection des intrusions et des vulnérabilités, et la veille sur les menaces. Les rôles de signalement, les seuils et les délais internes ci-dessus sont documentés et connus des personnes qui les appliquent.

8. Plan de réponse et de rétablissement

Alinéa 5(1)i) du Règlement.



L'atténuation et l'enquête ne suivent pas la notification : elles commencent dès la détection et se poursuivent en parallèle.

Ce que le plan prévoit

Élément	Contenu
Mise en œuvre graduée	L'intensité de la réponse augmente avec la gravité constatée, jusqu'à la suspension des transmissions et le gel des opérations d'un abonné. La coordination avec les tiers fournisseurs de services est prévue à chaque palier.
Mesures immédiates	Prises pendant l'enquête, pour prévenir ou atténuer toute autre atteinte à l'intégrité, à la confidentialité ou à la disponibilité : suspension d'une clé, retrait d'un accès, arrêt d'un lot, blocage d'un compte.
Atténuation des répercussions	Dans le délai minimum requis, au besoin par des processus manuels ou des solutions de rechange : dépôt du lot au jour ouvrable suivant, transmission par voie de secours convenue avec l'institution parraine, avis direct aux abonnés touchés.
Enquête	Amorcée immédiatement. Elle établit la cause première et détermine les répercussions sur les activités, les utilisateurs finaux et les autres fournisseurs.
Traitement de la cause première	Aussitôt que possible après son identification, de manière à préserver l'intégrité, la confidentialité et la disponibilité.
Signalement et coordination	Politiques de communication interne et externe, coordination avec les tiers, et respect des obligations légales de signalement — dont l'article 18 de la Loi et, s'il y a lieu, les obligations en matière de renseignements personnels.
Détermination de l'état des opérations	Récupération des données perdues à partir des sauvegardes et des journaux, réparation des atteintes à l'intégrité par contre-passation, et confirmation de l'invariant du grand livre avant reprise.
Tenue de documents	Pour chaque incident : chronologie, cause première, répercussions, mesures prises et résultat obtenu.

9. Notification des incidents

Article 18 de la Loi ; articles 11 et 12 du Règlement.

Le demandeur notifie sans délai, et au plus tard **48 heures** après avoir déterminé qu'un incident a des répercussions importantes, la Banque du Canada ainsi que les utilisateurs finaux, les autres fournisseurs de services de paiement et les chambres de compensation désignées qui sont touchés de manière importante.

Qui est visé, concrètement

Catégorie de la Loi	Ce qu'elle recouvre chez le demandeur
Utilisateurs finaux touchés	Les abonnés dont le solde, les opérations ou les données sont en cause, et, lorsque l'atteinte les vise directement, leurs contreparties — client payeur, fournisseur ou employé bénéficiaire — même si ces personnes n'ont aucune relation contractuelle avec le demandeur.
Autres fournisseurs de services de paiement	Ceux qui interviennent dans le même transfert électronique de fonds : le partenaire de virement Interac, et tout partenaire-distributeur ou éditeur tiers inscrit à ce titre dont les propres utilisateurs sont touchés par l'incident.
Chambres de compensation de systèmes désignés	La chambre de compensation d'un système de compensation et de règlement désigné au sens de la <i>Loi sur la compensation et le règlement des paiements</i> . Pour les activités du demandeur, il s'agit de Paielements Canada , chambre de compensation des systèmes par lesquels transitent ses fichiers et leur règlement — le Système automatisé de compensation et de règlement et Lynx —, et, pour le trajet C, de l'exploitant du système de virement Interac dans la mesure où celui-ci est désigné.

L'institution financière parraine n'appartient à aucune de ces trois catégories au sens de la Loi ; elle est avisée en vertu de l'entente qui lie le demandeur, et sans attendre, puisque c'est par elle que passent la suspension des transmissions et le traitement des retours.

Situation	Qualification retenue par le demandeur
Fonds d'un utilisateur final perdus de façon irrécouvrable ou devenus indisponibles de façon permanente	Répercussions importantes dans tous les cas.
Atteinte à l'intégrité du grand livre, des enregistrements d'opérations, ou erreur d'acheminement ou de calcul	Répercussions importantes dès qu'un solde d'abonné ou un paiement en est affecté.
Accès ou communication non autorisés de renseignements confidentiels	Répercussions importantes lorsqu'il en résulte un risque réel de préjudice grave, ou qu'un tel risque est créé.
Panne touchant la disponibilité des activités de paiement	Répercussions importantes au-delà d'une heure ouvrable, ou dès qu'un lot manque une heure de tombée.
Procédure d'insolvabilité	Répercussions importantes dans tous les cas.

Destinataire	Contenu de l'avis
Banque du Canada par le portail de la Banque	Coordonnées du demandeur et de la personne-ressource ; chronologie de l'incident — début, détection, détermination des répercussions importantes, résolution ; mode de détection et description sommaire ; activités de paiement touchées ; ampleur des répercussions, dont le nombre de personnes touchées ; mesures de réponse prises ; analyse de la cause première.
Utilisateurs finaux, fournisseurs et chambres touchés	Nom du demandeur ; description de l'incident avec les dates de début, de détection et de résolution ; répercussions propres au destinataire ; mesures correctives recommandées.

La Banque peut exiger des avis de suivi ; le demandeur y répond dans les formes et les délais prescrits, et poursuit les avis jusqu'à ce que tous les éléments requis aient été communiqués. Les avis, leurs destinataires et leurs dates sont conservés au dossier de l'incident.

10. Tiers fournisseurs de services et mandataires

Paragraphes 5(3) à 5(5) du Règlement.

Tiers	Dépendance	Surveillance exercée
Institution financière parraine	Compte en fiducie, identité d'émetteur, dépôt des fichiers, accusés et retours	Entente écrite ; évaluation annuelle ; rapprochement quotidien du relevé ; plan de réponse coordonné et voie de transmission de secours convenue.
Partenaire de virement Interac	Rail parallèle, envoi et dépôt	Entente écrite ; suivi des états de virement ; bascule sur le rail par lots si le partenaire est indisponible.
Hébergeur infonuagique	Ensemble des systèmes et des données	Entente écrite prévoyant la résidence des données au Canada, la journalisation et la notification des incidents ; restauration mise à l'essai.
Fournisseur de vérification d'entreprise	Vérification à l'ouverture et en continu	Entente écrite ; suivi de la qualité des résultats ; procédure manuelle de repli, l'activation d'un abonné étant reportée à défaut.
Partenaires-distributeurs mandataires	Provisionnement et gestion d'abonnés	Entente distincte ; aucun accès aux fonds, au compte en fiducie ni au grand livre ; revue des accès ; obligation de signalement des incidents au demandeur.

Le demandeur évalue régulièrement ces tiers, surveille l'exécution de leurs rôles et responsabilités, et suit la prestation des services. Les plans de réponse aux incidents sont coordonnés avec eux. La liste des contrats et la procédure de supervision figurent à la section 13 de la demande.

11. Mises à l'essai

Article 9 du Règlement.

Catégorie d'essai	Portée	Fréquence
Vérification et validation des contrôles	Double approbation, plafonds, moindre privilège, vérification de l'invariant du grand livre, blocage de la clôture sur écart de rapprochement.	Semestrielle
Essais fondés sur des scénarios	Perte de l'hébergeur ; indisponibilité de l'institution parraine un jour de dépôt ; fichier rejeté à l'entrée ; vague de retours au pire cas des fonds détenus ; compromission d'une clé d'API ; départ de l'unique personne détenant une procédure.	Annuelle
Essais relatifs aux modifications	Toute modification importante des systèmes, des politiques, des procédures ou des opérations, y compris un changement de tiers ou de format de fichier.	Avant chaque mise en service
Restauration des sauvegardes	Reconstitution du grand livre et confirmation de l'invariant du grand livre à partir des seules sauvegardes.	Semestrielle

Les essais associent les intéressés internes concernés, dont les décideurs et les personnes responsables de la gestion des risques opérationnels, et tiennent compte de la dépendance aux tiers fournisseurs de services. Chaque essai est documenté — date, méthode, résultats, mesures correctives — et ses résultats sont remis au cadre dirigeant.

12. Examen interne et examen indépendant

Articles 8 et 10 du Règlement.

Examen interne

Le cadre est examiné au moins une fois par année, et avant toute modification importante des activités ou des systèmes. L'examen porte sur la conformité au Règlement, sur l'efficacité du cadre à atteindre ses objectifs d'intégrité, de confidentialité et de disponibilité, sur la suffisance des ressources humaines et financières, sur les systèmes, politiques, procédures, processus et contrôles, ainsi que sur les arrangements conclus avec les tiers et les mandataires. Sa date, sa portée, sa méthodologie et ses résultats sont documentés, de même que les lacunes et les vulnérabilités relevées, et les résultats sont soumis au cadre dirigeant pour approbation.

Examen indépendant

Le cadre est soumis à une ressource indépendante et compétente, chargée de découvrir les lacunes et les vulnérabilités et d'en suivre la correction. Compte tenu du cumul des rôles décrit à la section 3, le demandeur considère cet examen non pas comme une formalité annuelle mais comme le principal contrepoids externe à sa taille.

Calendrier

Obligation	Échéance	Responsable
Approbation du cadre par le cadre dirigeant et le conseil	Annuelle, et après chaque modification importante	Cadre dirigeant et conseil
Examen interne du cadre	Annuel, et avant toute modification importante	Cadre dirigeant
Examen indépendant	Selon le cycle convenu avec la ressource indépendante	Ressource indépendante
Essais fondés sur des scénarios	Annuels	Exploitation et ingénierie
Vérification des contrôles et restauration des sauvegardes	Semestrielles	Ingénierie
Revue des accès	Trimestrielle	Cadre dirigeant
Rapprochement du compte en fiducie	Quotidien	Exploitation
Déclaration annuelle à la Banque du Canada	Au plus tard le 31 mars	Cadre dirigeant

13. Documentation et conservation

Articles 6 et 8(3) du Règlement ; obligations de tenue de documents.

- Le présent cadre est écrit, daté, versionné, et mis à la disposition de toute personne qui participe à sa mise en œuvre.
- Il est protégé contre la suppression, la destruction et la modification non autorisées : conservation versionnée, accès en écriture restreint, journalisation des modifications.
- Sont conservés au Canada pendant sept ans : le grand livre et les paiements, les journaux et la piste d'audit, les dossiers d'incident, les rapports d'examen et d'essai, les approbations du cadre dirigeant et du conseil.
- Chaque incident donne lieu à un dossier distinct portant sa chronologie, sa cause première, ses répercussions, les mesures prises, les avis émis et le résultat obtenu.

Documents liés. Description des services et des processus de paiement : question 6.1. Exemples de contrats et d'ententes : question 6.2. Diagrammes des processus de paiement : question 6.3. Schéma du flux de fonds et description du compte en fiducie : section 12. Contrats avec les tiers et procédure de supervision : section 13. Programme de conformité : section 16.

Annexe — Notes explicatives

Certaines cibles et certains mécanismes du présent cadre sont énoncés en une ligne dans les tableaux qui précèdent. La présente annexe les développe, pour le lecteur qui souhaite comprendre ce que le demandeur s'engage exactement à faire. Chaque note renvoie à la section d'où elle provient.

Note 1 — L'invariant du grand livre vérifié sans exception

Renvoi : section 2, cible d'intégrité.

Ce que le mot signifie

Un **invariant** est une affirmation sur l'état d'un système qui doit être vraie en tout temps. Le terme est emprunté aux mathématiques et à l'informatique : ce qui ne varie pas pendant que le reste varie. Le système, lui, bouge sans cesse — des opérations entrent, des écritures s'ajoutent, des soldes changent — et l'invariant est la propriété qui doit tenir avant et après chacun de ces changements.

La distinction avec un contrôle est déterminante. **Un contrôle qualifie une action** : un plafond examine une opération et l'autorise ou la refuse. **Un invariant qualifie un état** : il ne regarde aucune opération en particulier, il constate que l'ensemble est cohérent. Lorsqu'un contrôle échoue, il faut interpréter ; lorsqu'un invariant est faux, il n'y a rien à interpréter. L'état n'est pas imparfait, il est invalide, et l'enquête qui suit ne sert pas à établir *s'il* y a un problème mais *pourquoi* il y en a un. C'est ce qui justifie que la section 7 suspende les transmissions dès la première occurrence, sans attendre une seconde.

Un vestiaire en donne l'image la plus simple : la règle veut que chaque manteau reçoive un jeton ; l'invariant veut que le nombre de jetons remis égale le nombre de manteaux sur les supports. Nul besoin de savoir qui a pris quoi — si les deux nombres diffèrent, quelque chose ne va pas.

L'invariant du grand livre

Il s'agit de l'égalité posée à la section 4.2 de la description des services jointe à la question 6.1 :

$$\text{Fiducie} = \Sigma \text{ soldes des abonnés} + \Sigma \text{ réserves} + \text{produits} + \text{opérations en compensation}$$

Elle énonce que chaque dollar inscrit au compte de fiducie appartient à quelqu'un et que le grand livre sait à qui : soit à un abonné — son solde ou sa réserve —, soit au demandeur, par les frais portés aux produits, soit à une opération encore en cours entre l'initiation et le règlement. Si les deux membres de l'égalité divergent, c'est qu'un montant est apparu, a disparu, ou n'est plus attribuable. Chez un fournisseur qui détient des fonds d'utilisateurs finaux, c'est la définition même d'une atteinte à l'intégrité.

Vérifié signifie que l'égalité est recalculée et confrontée à **chaque écriture**, à la clôture de la transaction comptable, et non échantillonnée ni recalculée en fin de journée. La précision a son importance : entre le débit et le crédit d'une même écriture, l'égalité est momentanément fautive. L'invariant du grand livre porte donc sur chaque état **observable** du grand livre, et non sur chaque instant — c'est la transaction qui rend cette distinction possible, en ne laissant jamais voir l'état intermédiaire. Une écriture qui romprait l'invariant du grand livre est refusée avant d'être inscrite, plutôt que constatée après coup. C'est ce qui distingue un invariant d'un rapport de contrôle : le premier empêche, le second signale.

Sans exception énonce le seuil, qui est zéro. Là où une cible de disponibilité tolère une marge, celle-ci n'admet aucune occurrence : l'indicateur correspondant — le nombre de vérifications de l'invariant du grand livre en échec — est un

compteur qui doit demeurer nul, et non un taux à surveiller. C’est la raison pour laquelle la section 7 traite une occurrence unique comme un déclencheur, avec suspension des transmissions et qualification en quatre heures.

Ce que l’invariant du grand livre ne couvre pas. Il établit la **cohérence interne** du grand livre ; il ne démontre pas que les fonds sont effectivement à la banque. Un grand livre parfaitement cohérent peut décrire un compte en fiducie qui, dans les faits, ne porte pas la somme annoncée. C’est le **rapprochement quotidien** avec le relevé de l’institution financière parraine qui répond à cette seconde question. Les deux contrôles sont complémentaires et ne se remplacent pas : l’un vérifie que le registre se tient par lui-même, l’autre qu’il correspond à la réalité bancaire.

Le demandeur assume la conséquence de cet engagement : un échec de l’invariant du grand livre constitue par construction une atteinte à l’intégrité, et devient donc un candidat à la notification prévue à l’article 18 de la Loi dès qu’un solde d’abonné en est affecté, conformément à la qualification retenue à la section 9.

Note 2 — Les quatre mesures qui protègent l’initiation d’une opération

Renvoi : section 5, catégorie « Cybersécurité » ; voir aussi la section 6, gestion des accès.

Le risque principal, chez le demandeur, n’est pas qu’un tiers parvienne à lire des données : c’est qu’il parvienne à **initier une opération** au nom d’un abonné, et donc à déplacer des fonds. Les quatre mesures citées à la section 5 ne sont pas quatre variantes d’une même précaution. Chacune intervient à un moment différent de la même chaîne d’attaque.

Mesure	Ce qu’elle empêche	Ce qu’elle ne fait pas
Authentification à deux facteurs	Qu’un identifiant volé, deviné ou réutilisé d’un autre service suffise à entrer. L’accès exige en outre un second facteur détenu physiquement par la personne.	Elle ne protège pas contre un appareil déjà compromis, ni contre une clé d’API, qui n’ouvre pas de session.
Moindre privilège	Qu’un accès obtenu devienne un accès général. Chaque compte et chaque clé n’ouvrent que ce que le rôle exige, et la clé d’un abonné ne porte que sur ses propres données, par le cloisonnement multi-locataire.	Elle ne réduit pas la probabilité d’une compromission : elle en borne la portée.
Rotation des clés	Qu’une clé ou un secret compromis à l’insu du demandeur conserve indéfiniment sa valeur. Les clés ont une durée de vie limitée, sont remplacées périodiquement, et révoquées immédiatement au moindre doute.	Elle ne détecte pas la compromission : elle en raccourcit la fenêtre.
Double approbation des lots	Qu’une seule identité, même parfaitement légitime en apparence, transmette des fonds. Un lot créé par une personne doit être approuvé par une autre, et aucun compte ne cumule les deux droits sur un même lot.	Elle n’empêche pas l’intrusion : elle empêche que l’intrusion produise un paiement.

Pourquoi les quatre ensemble. Les trois premières mesures reposent sur le secret : elles rendent une compromission moins probable, moins étendue et moins durable, mais aucune ne survit à un attaquant qui détient effectivement un accès légitime. La quatrième ne repose pas sur le secret du tout : elle exige **deux identités distinctes**, et conserve donc son effet même lorsque les trois autres ont échoué. C'est la raison pour laquelle elle figure aussi, à la section 3, parmi les contrepoids au cumul des rôles.

Cette qualité a une condition, et le demandeur la nomme : la double approbation ne produit son effet que si la seconde personne **existe réellement** et n'est pas le cadre dirigeant lui-même. C'est pourquoi le présent cadre fait du recrutement d'une seconde personne habilitée une condition d'activation de la fonction de paiement, et non un objectif ultérieur.

Note 3 — Le risque de fraude porté par l'abonné

Renvoi : section 5, catégorie « Fraude » ; voir aussi la section 5.5 de la question 6.1.

Le risque de fraude du demandeur n'est pas d'abord celui d'un intrus : c'est celui d'un **abonné**, c'est-à-dire d'une personne à qui la plateforme a été ouverte régulièrement. Il prend deux formes, qui n'appellent pas les mêmes mesures.

Le prélèvement sans entente valide

Un abonné initie un encaissement sur une personne qui n'a jamais signé d'entente de débit préautorisé, ou qui en a signé une pour un autre montant, une autre échéance ou un autre bénéficiaire, ou encore une entente expirée ou révoquée. Le geste peut être une négligence — des coordonnées reprises d'un ancien dossier, une entente non mise à jour après un changement de montant — comme il peut être délibéré. Le résultat est le même : le payeur conteste, l'opération revient, et la règle H1 demande qui répondait de la validité de l'entente.

L'abonné qui détourne la plateforme

Cas plus grave, parce qu'il n'est pas une défaillance de contrôle à l'intérieur d'un compte légitime : le compte lui-même ne l'est pas. L'abonné souscrit dans le but d'encaisser auprès de personnes qui ne sont pas ses clients, ou son activité déclarée sert de couverture. La plateforme fonctionne alors exactement comme prévu — c'est l'usage qui est frauduleux.

Pourquoi ce risque pèse sur le demandeur et non sur l'abonné seul. Le modèle retenu à la section 5.5 de la question 6.1 fait du demandeur le **bénéficiaire inscrit**, pour le compte de l'abonné : une seule identité d'émetteur auprès de l'institution parraine, une seule lettre d'engagement du bénéficiaire. C'est donc le demandeur, et non l'abonné, qui répond devant l'institution parraine et devant la règle H1 de la validité de chaque prélèvement. La faute de l'abonné devient sa responsabilité, et le remboursement du payeur, sa charge si le solde de l'abonné ne suffit pas. Ce risque est le prix assumé d'un modèle qui évite à chaque abonné d'avoir à obtenir sa propre identité d'émetteur.

Les mesures, et leur ordre

Mesure	Moment	Effet recherché
Vérification d'entreprise préalable	Avant l'activation	Écarter l'abonné illégitime avant qu'il n'ait accès au rail : existence, propriété effective, sanctions, adresse, représentant autorisé. Aucune fonction de paiement n'est activée sans vérification concluante.
Secteurs d'activité exclus	Avant l'activation	Refuser d'emblée les activités dont le taux de contestation est structurellement élevé. La liste figure au contrat d'abonnement.
Plafonds par abonné	À chaque lot	Borner ce qu'un abonné peut prélever avant que quiconque s'en aperçoive : 50 000 \$ par jour par défaut, ajustable à la fiche.
Surveillance du taux de retour	En continu	C'est le signal de détection réel. Un abonné qui prélève sans droit produit des contestations, et le taux s'en ressent avant que la fraude ne soit établie.
Droit d'audit sur les ententes	Sur déclenchement	Exiger de l'abonné la preuve des ententes détenues, en particulier lorsque le taux de retour a franchi son seuil.

Mesure	Moment	Effet recherché
Retenue et réserve	En permanence	Absorber la conséquence financière : cinq jours ouvrables de retenue et 10 % du volume de débits sur trente jours, dimensionnés sur le délai de contestation.
Suspension et gel	Sur incident	Arrêter les opérations de l'abonné visé, jusqu'au gel de son solde, selon la gradation prévue à la section 8.

Une limite que le demandeur énonce. Il ne détient pas les ententes de débit préautorisé : elles sont signées par le payeur au bénéfice de l'abonné, et c'est l'abonné qui en conserve la preuve. Au moment du prélèvement, le demandeur ne peut donc pas vérifier l'existence d'une entente ; il vérifie qu'une entente est *déclarée* au dossier. Le contrôle est nécessairement indirect, et c'est pourquoi il repose sur trois appuis plutôt qu'un : la sélection à l'entrée, la mesure du taux de retour, et le droit d'audit. Le volet de ce risque qui relève du recyclage des produits de la criminalité est traité par le programme de conformité joint à la section 16.

Note 4 — La protection des données des contreparties

Renvoi : section 5, catégorie « Gestion des données et des renseignements » ; voir aussi les sections 4 et 6.

La particularité du demandeur, en matière de confidentialité, tient à l'identité des personnes exposées. Les données les plus sensibles qu'il détient ne concernent pas ses clients, mais les **contreparties** de ceux-ci : le numéro de compte bancaire du payeur, celui de l'employé qui reçoit sa paie, celui du fournisseur payé. Ces personnes n'ont aucune relation contractuelle avec le demandeur, ne l'ont pas choisi, et ne sauraient pas nécessairement vers qui se tourner. Le demandeur en tire une conséquence : la protection de ces données ne peut reposer sur la vigilance de la personne concernée, comme c'est le cas d'un mot de passe, mais uniquement sur ses propres mesures.

Mesure	Ce qu'elle protège	Ce qu'elle ne protège pas
Chiffrement en transit	Les données qui circulent : appels d'interface, session de portail, transmission d'un fichier, échanges avec les tiers. Elles ne sont pas lisibles par qui les intercepte en chemin.	Ni le point de départ ni le point d'arrivée. Une fois la donnée reçue, c'est le chiffrement au repos et le cloisonnement qui prennent le relais.
Chiffrement au repos	Le support : disque, copie de sauvegarde, image de machine, poste de travail perdu ou volé. Quiconque obtient le support sans la clé n'obtient rien de lisible — y compris, le cas échéant, chez l'hébergeur.	Une application compromise. Le système doit pouvoir déchiffrer pour fonctionner : un attaquant qui s'exécute à l'intérieur de l'application lit des données déchiffrées. Le chiffrement au repos défend le support, non le système en marche.
Cloisonnement par locataire	La séparation entre abonnés : toute lecture est bornée au locataire qui la demande, de sorte qu'aucun abonné, aucun de ses utilisateurs et aucun partenaire-distributeur ne peut atteindre les données d'un autre. C'est le contrôle qui répond au caractère mutualisé de la plateforme.	Un accès légitime détourné à l'intérieur d'un même locataire. Ce cas relève de la gestion des accès et de la journalisation.
Journalisation des accès	Rien, au sens strict : elle n'empêche aucun accès. Elle rend chaque accès attribuable et l'enchaînement reconstituable , ce qui est la condition de tout le reste.	Elle ne vaut que si elle est elle-même protégée : les journaux sont conservés hors de portée des comptes qu'ils observent, et leur altération est traitée comme un incident.

Pourquoi la journalisation est indispensable et non accessoire. Lorsqu'un accès non autorisé survient, le demandeur doit déterminer **quelles** données ont été atteintes et **qui** en est affecté — c'est la condition d'un avis utile, tant au titre de l'article 18 de la Loi qu'au titre des obligations applicables en matière de renseignements personnels. Sans journal d'accès, cette question n'a pas de réponse : le demandeur serait réduit à supposer le pire ou à ne rien dire, et aucune de ces deux issues n'est acceptable. C'est aussi pourquoi la qualification retenue à la section 9 pour un accès non autorisé repose sur le **risque réel de préjudice grave** : c'est un jugement qui suppose de savoir ce qui a été touché.

Conservation et effacement. Le contrat d'abonnement prévoit que les données personnelles peuvent être anonymisées sur demande, tandis que le grand livre et les paiements sont conservés sept ans au Canada à titre de piste d'audit financière. Ces deux exigences ne se contredisent pas : l'anonymisation porte sur les données personnelles rattachées à une contrepartie,

non sur les écritures comptables, qui demeurent nécessaires pour établir qu'aucun fonds n'a disparu. Le cloisonnement par locataire est ce qui rend cette distinction praticable — il permet d'atteindre les données d'une seule contrepartie sans toucher au registre.

Note 5 — Le fichier de la norme 005

Renvoi : section 2, cible d'intégrité ; voir aussi les sections 5 et 6, et la définition donnée à l'annexe de la question 6.1.

Le fichier de la norme 005 est le seul objet par lequel les instructions du demandeur entrent dans le système de compensation. Tout ce que la plateforme a calculé, contrôlé et écrit au grand livre finit dans ce fichier, et rien n'en sort autrement. C'est ce qui explique qu'un format de fichier figure parmi les cibles d'**intégrité** de la section 2 plutôt que parmi les questions techniques.

Ce que contient le fichier

Enregistrement	Rôle
A — en-tête	Unique, en tête du fichier. Porte l'identité d'émetteur attribuée par l'institution parraine — numéro de client émetteur et centre de traitement — ainsi qu'un numéro de création de fichier séquentiel qui identifie ce dépôt et interdit qu'un même fichier soit présenté deux fois.
C et D — détail	Un enregistrement de crédits, un de débits. Chacun porte plusieurs opérations : montant, date de règlement, institution et transit du compte visé, nom de la contrepartie, référence croisée, code d'opération de la norme 007.
E, F, I, J	Corrections, annulations et retours, intercalés avec les enregistrements de détail.
Z — totaux	Unique, en fin de fichier. Porte le décompte des opérations et la somme des montants, que l'institution recalcule pour vérifier qu'aucune ligne n'a été perdue ni altérée en chemin.

Le fichier est à **largeur fixe** : chaque enregistrement compte exactement le même nombre de caractères, et chaque information occupe une position déterminée. La spécification usuelle est un enregistrement de 1 464 caractères, formé d'un en-tête de 24 caractères et de six segments de 240 caractères, soit jusqu'à six opérations par enregistrement.

Pourquoi un seul caractère fait rejeter le tout

Dans un format à largeur fixe, rien ne signale où commence un champ : seule sa position le dit. Un caractère inséré ou manquant décale tout ce qui suit, et les champs ne deviennent pas illisibles — ils deviennent *autre chose*. Un montant se lit comme une date, un transit comme un numéro de compte. C'est précisément ce qu'une lecture partielle ne détecterait pas, et c'est pourquoi la vérification est structurelle : la longueur de chaque enregistrement, la concordance des totaux de l'enregistrement Z avec le détail, et l'homogénéité de l'encodage. À défaut, l'institution rejette le fichier entier plutôt que d'en deviner le contenu.

Type de rejet	Cause usuelle	Conséquence
Rejet du fichier indicateur « taux de rejet de fichier »	Longueur d'enregistrement non conforme, totaux de l'enregistrement Z discordants, encodage mixte ou caractères de contrôle, en-tête invalide.	Aucune opération du lot n'entre dans la compensation. Rien n'a bougé : il faut corriger et redéposer, et respecter l'heure de tombée pour ne pas décaler le règlement d'un jour ouvrable.
Rejet d'un article indicateur « taux de rejet d'article »	Numéro de transit ou de compte invalide, coordonnées de contrepartie incohérentes, code d'opération refusé.	Le lot passe, la ligne est écartée. L'écriture correspondante est contre-passée selon le trajet D.

Le dépôt est un point de non-retour. Une fois le fichier accepté et présenté à la compensation, les opérations qu'il porte ne s'annulent plus : elles se défont par un retour, avec les délais et les frais qui s'y attachent. Tout ce qui peut être vérifié doit donc l'être **avant** le dépôt. C'est ce qui donne leur place aux contrôles décrits ailleurs dans le présent cadre — les plafonds appliqués à la création du lot, la double approbation, et le jeu d'essais automatisé de conformité au format prévu au cycle de développement sécurisé de la section 6. Le fichier est le dernier moment où une erreur coûte peu.

Une seule identité d'émetteur pour tous les abonnés. L'en-tête ne porte pas le nom de l'abonné mais celui du demandeur, conformément au modèle retenu à la section 5.5 de la question 6.1. C'est pourquoi le nom de l'abonné est porté dans la contrepartie et la référence croisée de chaque opération : c'est la seule façon, pour le payeur, de reconnaître le prélèvement sur son relevé, et pour le demandeur, d'imputer un retour au bon abonné.

Note 6 — Les deux indicateurs de confidentialité

Renvoi : section 2, objectif de confidentialité ; voir aussi les sections 7 et 9.

L'objectif de confidentialité est suivi par deux indicateurs qui, malgré leur voisinage dans le tableau, ne sont pas de même nature. Le premier compte des **tentatives** et sert à voir venir ; le second compte des **faits établis** et sert à rendre compte. Les confondre conduirait à les traiter de la même manière, ce qui serait une erreur dans les deux sens.

Indicateur	Ce qu'il compte	Cible	Ce qu'il déclenche
Accès refusés anormaux	Les accès que le système a refusés et qui s'écartent du profil habituel : volume inhabituel, heure inhabituelle, provenance inhabituelle, ou forme révélatrice — un grand nombre de comptes différents essayés depuis une même source, ou un même compte essayé contre plusieurs locataires.	Aucune cible chiffrée	Une vérification, et la suspension de la clé ou du compte en cause s'il y a lieu, selon la section 7.
Incidents de confidentialité	Les cas où un accès ou une communication non autorisés ont effectivement eu lieu, quelle qu'en soit l'origine : • intrusion, identifiant ou clé d'API compromis ; • consultation sans motif par une personne pourtant autorisée, chez le demandeur ou chez un abonné ; • défaut de configuration ou de cloisonnement rendant une donnée lisible au-delà de son locataire ; • erreur d'acheminement — relevé, avis ou fichier transmis au mauvais destinataire ; • incident survenu chez un tiers : hébergeur, partenaire de virement, fournisseur de vérification, partenaire-distributeur ; • perte ou vol d'un poste de travail, d'un support ou d'une copie de sauvegarde.	Zéro	L'ouverture d'un incident, sa qualification au regard du risque réel de préjudice grave selon la section 9, et la notification s'il y a lieu.

Pourquoi le premier n'a délibérément pas de cible. Un système refuse des accès en permanence, et c'est normal : session expirée, clé révoquée, utilisateur d'un abonné qui tente par mégarde d'atteindre au-delà de son locataire. Un refus n'est pas une défaillance — c'est la preuve que le contrôle fonctionne. Si le demandeur se donnait pour cible de faire baisser ce compteur, il se donnerait pour objectif de *moins voir*, alors que sa fonction est précisément de rendre visible ce qui se produit. Une hausse est donc traitée comme un signal à interpréter, jamais comme un résultat à corriger. Le second indicateur, lui, porte une cible de zéro, parce qu'il ne compte pas des tentatives mais des atteintes.

La limite du premier indicateur, et ce qui la comble. Un accès refusé laisse une trace parce qu'il a été refusé. Le cas dangereux est l'inverse : l'accès qui n'a jamais été refusé — un identifiant légitime employé par la mauvaise personne, une donnée rendue lisible par une configuration erronée, un tiers qui consulte ce qu'il n'aurait pas dû recevoir. Aucun de ces cas

ne fait monter le compteur des refus, et pourtant chacun est un incident de confidentialité. Le nombre d'accès refusés anormaux ne borne donc pas le nombre d'incidents : il ne couvre qu'une partie du champ. C'est la **journalisation des accès** — y compris ceux qui ont été accordés — qui couvre l'autre, et c'est la raison pour laquelle elle figure parmi les mesures de la section 5 plutôt que parmi les commodités d'exploitation.

Note 7 — Le lot manqué et l'heure de tombée

Renvoi : section 2, objectif de disponibilité ; voir aussi les sections 5 et 7.

De quel lot s'agit-il. Un lot est le regroupement, en un fichier de la norme 005, des opérations d'une même nature préparées dans la journée : un lot de virements de **débit** pour les encaissements du trajet A, un lot de virements de **crédit** pour les décaissements du trajet B. Le virement Interac du trajet C n'est pas concerné : il se transmet à l'unité et se règle au dépôt, sans fenêtre quotidienne.

Ce qu'est l'heure de tombée. C'est l'heure, fixée chaque jour ouvrable par l'institution financière parraine, au-delà de laquelle un fichier reçu n'est plus porté à la compensation du jour mais à celle du jour ouvrable suivant. Elle ne se négocie pas au cas par cas et ne dépend pas du demandeur : c'est une contrainte subie, au même titre que le calendrier des jours ouvrables.

Ce que « manquer un lot » veut dire. Des opérations étaient prêtes à partir et ne sont pas parties à temps. Les causes possibles sont connues : une approbation obtenue trop tard, un fichier rejeté à l'entrée et corrigé après l'heure, une indisponibilité de la plateforme ou de l'institution parraine, ou simplement une préparation entamée trop près de la limite.

Pourquoi c'est une cible de disponibilité et non d'intégrité. Un lot manqué ne fait perdre aucun fonds et ne fausse aucune écriture : les opérations demeurent au grand livre, portées en compensation, et partent le jour ouvrable suivant. Rien n'est à corriger, tout est à retarder. C'est la raison pour laquelle cette cible figure parmi les objectifs de disponibilité, et pourquoi le demandeur écrit à la section 1 qu'un traitement reporté d'une journée ouvrable est une gêne et non une perte.

La conséquence n'est pourtant pas symétrique. Un encaissement retardé retarde la disponibilité du solde de l'abonné, ce qui se rattrape. Un décaissement retardé peut rendre une **paie** ou une **remise gouvernementale** en retard, et les conséquences de ce retard — pénalités, intérêts, relation avec un employé — appartiennent à l'abonné, qui n'en est pas l'auteur. C'est pourquoi l'indicateur est relevé quotidiennement plutôt que mensuellement, et pourquoi une échéance de paie ou de remise est traitée comme une journée à risque au même titre qu'un mois de pointe.

Le report se compte en jours ouvrables. Les fichiers ne circulent ni les fins de semaine ni les jours fériés. Un lot manqué la veille d'un congé ne se décale donc pas d'un jour civil mais de plusieurs, ce qui déplace d'autant la date de règlement portée dans le fichier. Les mesures qui en découlent sont ordinaires mais explicites : préparer et approuver les lots en début de journée plutôt qu'à l'approche de la limite, surveiller quotidiennement l'écart entre l'heure de transmission et l'heure de tombée, prévenir les abonnés touchés dès qu'un report est acquis, et appliquer la procédure de dégradation prévue à la section 5 lorsque l'indisponibilité vient d'un tiers.

Note 8 — Le point d'entrée des instructions

Renvoi : section 4, portail et interface de programmation ; voir aussi les sections 6 et 7.

Une **instruction** est une demande, non une exécution. Elle porte une intention — encaisser tel montant sur tel client payeur, décaisser tel montant vers tel bénéficiaire — et rien de plus. Elle ne devient une opération qu'après les contrôles à l'initiation, et elle ne devient un mouvement de fonds qu'après la mise en lot, la double approbation et le dépôt. Le point d'entrée est donc l'endroit de la plateforme où l'on accorde le **moins** de confiance et où l'on vérifie le plus.

Les seules voies d'entrée

Voie	Qui l'emprunte	Ce qui l'authentifie
Portail libre-service	Un utilisateur désigné par l'abonné, personne physique.	Une session nominative, avec authentification à deux facteurs et droits distincts de préparation et d'approbation.
Interface de programmation	L'application de l'abonné, sans intervention humaine à chaque appel.	Une clé d'API, qui n'ouvre pas de session : d'où la rotation, la révocation immédiate et la restriction de portée décrites à la note 2.
Portail partenaire	Un partenaire-distributeur, pour provisionner et gérer ses abonnés.	Une clé partenaire distincte. Cette voie ne porte aucune instruction de paiement et n'ouvre ni le compte en fiducie ni le grand livre.

Pourquoi l'ensemble est fermé. Aucune instruction n'entre autrement : ni par courriel, ni par téléphone, ni par un fichier déposé quelque part, ni par une intervention manuelle dans la base de données. Ce n'est pas une commodité, c'est ce qui rend les contrôles des sections 6 et 7 **exhaustifs** plutôt que partiels. Une seule voie informelle supplémentaire — une exception consentie à un abonné pressé, un correctif appliqué à la main — suffirait à ouvrir un trou dans chacun d'eux à la fois.

Une instruction n'est jamais crue sur parole

La plateforme revalide chaque instruction pour son propre compte : entente de débit préautorisé déclarée au dossier, abonné vérifié et actif, solde disponible réserve déduite, plafonds. Elle ne s'en remet jamais au fait que l'appelant aurait déjà vérifié. Cette règle vaut pour toutes les voies, y compris lorsque l'instruction provient d'une application qui exerce elle-même une fonction d'administration financière : un logiciel client peut être défaillant, mal configuré ou compromis, et sa qualité de client ne lui confère aucune confiance particulière.

Ce qui explique le classement de la section 4. Le portail et l'interface sont classés d'importance *élevée* mais de sensibilité *moyenne*, et l'écart n'est pas une inadvertance. Leur indisponibilité suspend le service — aucune instruction ne peut plus entrer, les opérations déjà initiées suivent leur cours — ce qui en fait un actif important. Mais ils ne détiennent ni les fonds ni le registre : leur compromission ne permet pas d'altérer un solde, seulement de tenter d'initier des opérations, que les contrôles suivants ont pour fonction d'arrêter. C'est le grand livre et le compte en fiducie qui portent la sensibilité la plus élevée, et non la porte par laquelle on y adresse des demandes.

Note 9 — La séparation des droits de préparation et d’approbation

Renvoi : section 6, gestion des accès ; voir aussi les sections 3 et 8, et la note 2.

La note 2 explique pourquoi la double approbation résiste là où les autres mesures cèdent. La présente note décrit comment elle est **construite**, car son effet dépend entièrement de sa mise en œuvre : une double approbation qui repose sur la bonne volonté n’en est pas une.

Deux droits distincts, et une règle qui ne se contourne pas

Droit	Ce qu’il permet	Ce qu’il ne permet pas
Préparation	Créer un lot, y intégrer des opérations, le modifier, le soumettre à l’approbation.	Le transmettre. Un lot préparé n’est qu’une intention tant qu’il n’est pas approuvé.
Approbation	Autoriser la transmission d’un lot, après en avoir vu le décompte, le total et les écarts par rapport à l’ordinaire.	En modifier le contenu. Approuver, c’est accepter ou refuser ce qui est présenté, non le corriger soi-même.

De quelles personnes s’agit-il. De deux **personnes physiques** distinctes, employées ou mandatées par le demandeur, agissant chacune sous un compte nominatif protégé par une authentification à deux facteurs. Ni un rôle, ni un service automatisé, ni deux comptes détenus par le même individu ne satisfont à l’exigence. C’est le point où l’automatisation s’arrête : une instruction peut entrer par l’interface de programmation sans aucune intervention humaine, comme le décrit la note 8, mais aucun lot ne quitte la plateforme sans que deux personnes l’aient vu.

Les deux droits sont des permissions distinctes, attribuées séparément à la fiche de chaque utilisateur. Mais la règle déterminante ne porte pas sur les permissions détenues : elle porte sur le **lot**. La plateforme refuse l’approbation d’un lot par le compte qui l’a préparé, quels que soient les droits de ce compte. Une personne peut donc détenir les deux droits — ce qui est courant dans une petite équipe — sans jamais pouvoir approuver son propre lot.

Un contrôle de construction, non de politique. Le refus est prononcé par la plateforme, pas par une consigne. Il ne peut être levé ni par l’abonné, ni par un partenaire-distributeur, ni par le cadre dirigeant du demandeur : aucun droit d’administration ne comporte la faculté de transmettre seul. Chaque lot conserve par ailleurs l’identité du préparateur, celle de l’approbateur et les horodatages correspondants, de sorte que l’exercice du contrôle est vérifiable après coup et non seulement affirmé.

Ce que cette séparation attrape réellement

Le geste malveillant est le cas que l’on cite ; l’erreur ordinaire est le cas que l’on rencontre. Un lot préparé deux fois, une date de règlement de la semaine précédente, un montant saisi en dollars là où la plateforme attend des cents, un fichier de la veille resoumis : ces situations ne relèvent d’aucune intention et coûtent pourtant un retour, des frais et une explication à donner à un abonné. La seconde lecture intervient au dernier moment où l’erreur se corrige encore sans conséquence — avant le dépôt, qui est le point de non-retour décrit à la note 5. C’est pourquoi l’approbateur voit le décompte et le total du lot : ce sont les deux mêmes valeurs que l’enregistrement Z présentera à l’institution, et un écart entre ce qui était attendu et ce qui est affiché se remarque sans expertise particulière.

La faiblesse connue, et ce qui la limite. Une double approbation devient une formalité si l’approbateur signe sans regarder. Le demandeur ne prétend pas éliminer ce risque, qui tient au comportement et non au système ; il le réduit en présentant à l’approbation des éléments comparables d’un jour à l’autre — décompte, total, écarts — plutôt qu’une liste d’opérations à

parcourir, et en faisant échouer le lot de plein droit lorsqu'un plafond est dépassé, sans laisser à l'approbateur le soin de s'en apercevoir.

Aucune dérogation d'urgence. Si la seconde personne est absente, le lot n'est pas transmis : il attend. Le cadre ne prévoit aucun mécanisme d'exception permettant de passer outre, parce qu'un tel mécanisme deviendrait la voie normale au premier jour de pointe. La conséquence est assumée et se lit à la note 7 : un lot reporté d'un jour ouvrable est une gêne, tandis qu'un lot transmis par une seule personne est une atteinte au contrôle. La mesure qui répond à cette contrainte n'est pas une dérogation mais une **suppléance nommée**, prévue à la section 5 au titre des ressources humaines.

Note 10 — Le chiffrement en transit

Renvoi : section 6, sécurité des réseaux ; voir aussi la note 4, qui le situe parmi les mesures de confidentialité.

La note 4 indique ce que le chiffrement en transit protège et ce qu'il ne protège pas. La présente note précise **quels canaux** il couvre chez le demandeur, et où s'arrête sa portée.

Canal	Ce qui y circule	Portée
Portail libre-service poste de l'utilisateur ↔ plateforme	Session, instructions, soldes, relevés.	Du poste jusqu'au service, sans point intermédiaire où le contenu circulerait en clair.
Interface de programmation application de l'abonné ↔ plateforme	Instructions, clé d'API, réponses.	Même portée. La clé circule protégée, ce qui ne dit rien de la manière dont l'appelant la conserve chez lui.
Transmission du fichier 005 plateforme → institution parraine	Coordonnées bancaires de tiers, montants, dates de règlement.	Le canal est celui qu'impose l'institution parraine. La protection y est autant contractuelle que technique.
Notifications sortantes plateforme → systèmes de l'abonné	Changements d'état d'une opération ou d'un lot.	Chiffrées jusqu'à la réception. Ce qui en est fait ensuite relève du dispositif de l'abonné.
Échanges internes entre composants et avec l'hébergeur	Écritures, données, journaux.	Chiffrés également : le demandeur ne traite pas son propre périmètre comme un réseau de confiance.

Trois garanties, dont une souvent oubliée

Un canal chiffré apporte trois choses : le contenu n'est pas **lisible** en chemin ; il n'est pas **modifiable** en chemin sans que l'altération se remarque ; et le service joint est bien celui que l'on croit joindre. La deuxième est celle que l'on cite le moins et qui compte le plus ici : s'agissant d'une instruction de paiement, un montant *altéré* en chemin est une conséquence plus grave qu'un montant *lu*. La confidentialité protège la contrepartie ; l'intégrité en transit protège le paiement lui-même.

Ce que le chiffrement ne dit pas : qui appelle. Un canal parfaitement chiffré établi par un appelant illégitime demeure un canal parfaitement chiffré. Le chiffrement protège la conversation, il n'en désigne pas les participants. C'est l'authentification — session à deux facteurs ou clé d'API, selon la voie — qui répond à cette question, et c'est un contrôle distinct, décrit à la note 8. Les confondre est l'erreur la plus commune en la matière : elle conduit à croire une instruction sur la seule foi du canal par lequel elle est arrivée.

La portée s'arrête à la réception. Un canal chiffré protège les données jusqu'à leur destinataire, et pas au-delà. Ce que l'institution parraine, un partenaire-distributeur ou l'application d'un abonné en font ensuite relève de leur propre dispositif. Le demandeur ne peut ni le vérifier en continu ni s'y substituer : il le traite par les ententes écrites décrites à la section 10, qui prévoient notamment l'obligation de lui signaler tout incident. C'est aussi la raison pour laquelle une erreur d'acheminement figure parmi les origines d'incident de confidentialité énumérées à la note 6 — le chiffrement est sans effet sur un envoi correctement protégé mais adressé à la mauvaise personne.

Note 11 — La qualification d'un incident et le délai de quatre heures

Renvoi : section 2, objectif de détection, et section 7 ; voir aussi les sections 8 et 9.

Qualifier, ce n'est ni détecter ni comprendre. C'est décider, à partir de ce que l'on sait à un moment donné, dans laquelle des trois situations suivantes on se trouve.

Issue de la qualification	Ce qu'elle entraîne
Ce n'est pas un incident	L'événement relève du fonctionnement normal — un accès refusé isolé, un rejet d'article corrigé. Consigné, sans suite.
Incident sans répercussions importantes	Dossier d'incident ouvert, enquête, mesures, documentation. Aucune notification.
Incident ayant des répercussions importantes	Tout ce qui précède, plus la notification de la Banque du Canada et des personnes touchées, selon la qualification retenue à la section 9.

Pourquoi le demandeur se donne un délai que la Loi ne lui impose pas. Le délai de 48 heures de l'article 18 ne court pas à partir de la survenance, ni de la détection : il court à partir du moment où le fournisseur **détermine** que l'incident a des répercussions importantes. Un fournisseur qui tarde à déterminer retarde d'autant son obligation de notifier. Le demandeur ferme cette porte par une contrainte interne : la qualification doit être prononcée dans les **quatre heures** suivant la détection. Ce délai n'est pas une exigence réglementaire, c'est la garantie que l'exigence réglementaire ne puisse pas être différée par l'inaction.

Pourquoi quatre heures et non moins. Qualifier suppose de réunir un minimum de faits : quelles données sont en cause, quels abonnés et quelles contreparties sont touchés, combien, et si des fonds ont bougé. Sans les journaux d'accès décrits à la note 4, certaines de ces questions n'ont pas de réponse ; avec eux, elles en ont une en quelques heures. Une qualification prononcée en quinze minutes serait une devinette, et une devinette engage autant qu'une détermination.

Pourquoi quatre heures et non davantage. Parce que la qualification commande la suite : c'est elle qui déclenche le compte de 48 heures, et c'est elle qui oriente les mesures — un incident d'intégrité impose la suspension des transmissions, un incident de confidentialité impose la révocation d'accès. Différer la qualification, c'est différer ces deux choses à la fois.

Une qualification provisoire plutôt qu'un report. Si les faits demeurent insuffisants au terme des quatre heures, le demandeur qualifie l'incident sur la base de ce qui est connu, en retenant l'hypothèse la plus défavorable, quitte à réviser ensuite à la lumière de l'enquête. Il ne suspend pas la qualification en attendant d'en savoir plus. Une révision se documente et, le cas échéant, s'accompagne d'un avis de suivi ; un silence prolongé, lui, ne se rattrape pas.

Le délai se compte en heures réelles. Les soixante minutes de détection, les quatre heures de qualification et les quarante-huit heures de notification courent sans égard aux jours ouvrables, aux fins de semaine et aux jours fériés — à la différence du traitement des lots, dont la note 7 rappelle qu'il suit le calendrier de la compensation. Un incident survenu un vendredi soir se qualifie le vendredi soir.

La qualification appartient au cadre dirigeant, conformément à la section 3, et elle est journalisée : l'heure de détection, l'heure de qualification, l'issue retenue et les faits sur lesquels elle repose. C'est cette chronologie que la Banque demande dans l'avis d'incident décrit à la section 9. Enfin, la qualification ne retarde jamais les mesures immédiates : celles-ci commencent à la détection, comme le montre la chronologie de la section 8.

Note 12 — Le taux de retour d'un abonné

Renvoi : section 7 ; voir aussi la note 3, qui en fait le signal de détection de la fraude, et la section 5.

Le taux de retour rapporte, pour un abonné donné, les encaissements qui reviennent à ceux qui sont partis : provision insuffisante, compte fermé ou introuvable, ordre d'arrêt de paiement, contestation d'une entente de débit préautorisé. Il est suivi par abonné et non pour la plateforme entière, parce qu'un taux global dissimulerait précisément ce qu'il s'agit de voir — un abonné en difficulté parmi cent qui vont bien.

La difficulté de mesure, et comment le demandeur la traite

Un retour n'arrive pas en même temps que l'opération qui le provoque. Une provision insuffisante revient en quelques jours ; une contestation d'entente peut survenir jusqu'à **90 jours civils** après le prélèvement lorsque le payeur est un particulier. Un taux calculé sur les opérations récentes est donc systématiquement **optimiste** : les débits les plus récents n'ont pas encore eu le temps de revenir. Un abonné nouvellement activé, ou dont le volume croît vite, paraît meilleur qu'il n'est — et c'est exactement le moment où l'on décide de ses plafonds.

Le demandeur en tire deux lectures distinctes plutôt qu'un chiffre unique :

Lecture	Fenêtre	Ce à quoi elle sert
Réaction	Courte, dominée par les retours pour provision insuffisante	Voir vite qu'un abonné dérape, et suspendre au besoin. Elle réagit, elle ne conclut pas.
Décision	Mûrie, alignée sur le délai de contestation applicable	Fixer ou réviser un plafond et la réserve sur des chiffres que le temps ne démentira plus.

L'indicateur détecte, il ne diagnostique pas. Un taux qui monte admet au moins trois explications, qui appellent trois réponses opposées : la clientèle de l'abonné se détériore, pour des raisons qui lui échappent ; le processus de l'abonné est négligent — montants inexacts, ententes non tenues à jour, coordonnées périmées ; ou l'abonné prélève sans droit, au sens de la note 3. Le taux ne distingue pas ces cas. C'est le **droit d'audit sur les ententes** qui les distingue, et c'est la raison pour laquelle il est déclenché par le franchissement du seuil plutôt qu'exercé au hasard.

Le seuil est porté à la fiche de l'abonné, et non fixé une fois pour toutes à l'échelle de la plateforme : un secteur où l'on prélève des honoraires mensuels auprès d'une clientèle stable ne se compare pas à un secteur où la rotation est forte. Le seuil est établi à l'activation, d'après le secteur déclaré, puis révisé d'après l'historique observé.

Ce qui suit le franchissement du seuil est gradué, dans cet ordre : révision du plafond quotidien de l'abonné, révision de sa réserve, examen des ententes de débit préautorisé au titre du droit d'audit, puis, si les explications ne viennent pas, suspension des encaissements et gel du solde selon la section 8.

Un indicateur qui n'est pas seulement le sien. Le taux de retour intéresse aussi l'institution financière parraine, qui répond du demandeur devant la compensation comme le demandeur répond de ses abonnés. Un taux agrégé durablement élevé ne se solde pas par une remontrance : il met en cause l'identité d'émetteur et, avec elle, l'accès au rail. C'est ce qui explique que cet indicateur figure parmi les signaux surveillés en continu de la section 7, et non parmi les statistiques commerciales.

Note 13 — L’avis de sécurité d’un tiers

Renvoi : section 7 ; voir aussi les sections 4, 6 et 10, et les notes 6 et 11.

Tous les autres signaux du tableau de la section 7 sont produits par les systèmes du demandeur : ils mesurent ce qui se passe chez lui. Celui-ci est le seul à venir de l’extérieur, et à porter sur quelque chose qu’il n’a pas écrit. C’est ce qui justifie qu’il soit surveillé au même titre qu’un écart de rapprochement : une part du risque du demandeur réside dans des composants et des services dont il n’a pas la maîtrise.

D’où viennent ces avis

- **Des tiers sous entente** — hébergeur, institution financière parraine, partenaire de virement, fournisseur de vérification. Leur obligation de signalement est stipulée aux ententes décrites à la section 10.
- **Des éditeurs des composants employés** — systèmes d’exploitation, bases de données, cadres applicatifs, bibliothèques tierces, y compris celles dont dépendent d’autres bibliothèques.
- **Des sources publiques de vulnérabilités**, suivies par la veille prévue à la section 6.

Deux avis de nature opposée, qu’il ne faut pas traiter de la même façon. Le premier dit : « un incident s’est produit chez nous ». Il peut affecter les données ou le service du demandeur, et devient alors un incident du demandeur lui-même : il ouvre un dossier et se qualifie dans les quatre heures selon la note 11, la note 6 rangeant d’ailleurs l’incident survenu chez un tiers parmi les origines possibles d’une atteinte à la confidentialité. Le second dit : « une faiblesse existe dans un composant que vous employez ». Rien ne s’est produit ; c’est un avertissement, et il relève de la gestion des vulnérabilités et des correctifs de la section 6. Le premier déclenche un compte à rebours, le second une évaluation. Les confondre conduit soit à s’alarmer sans motif, soit à manquer une obligation de notification.

Le seuil est la pertinence, non la gravité

Le seuil retenu à la section 7 est « tout avis touchant un composant employé ». Une faille critique dans un logiciel que le demandeur n’emploie pas ne le concerne pas ; une faille moyenne dans le chemin qui produit le fichier de la norme 005 le concerne au premier chef. Cette formulation a une conséquence exigeante et assumée : elle suppose de **savoir ce que l’on emploie**. Elle repose donc sur le recensement des actifs de la section 4 et sur le suivi des dépendances applicatives prévu à la section 6. Un inventaire incomplet ne produit pas des avis manqués de façon visible — il produit un silence que rien ne distingue de l’absence de problème.

L’évaluation se fait dans cet ordre : le demandeur est-il exposé, compte tenu de la version employée, de sa configuration et du fait que le chemin vulnérable soit ou non atteignable ; que permettrait l’exploitation de la faiblesse ; existe-t-il une mesure d’atténuation applicable immédiatement, à défaut de correctif ; puis application du correctif dans le délai que commande sa gravité. Un avis touchant un actif classé critique à la section 4 — le grand livre, la production des fichiers, l’accès bancaire — est traité selon le délai le plus court, quelle que soit la gravité annoncée par l’éditeur.

La limite, et ce qui la compense. Le demandeur dépend d’un tiers pour être informé, et l’absence d’avis ne démontre pas l’absence de problème : un fournisseur peut ignorer son propre incident, ou tarder à le signaler. Deux choses limitent cette dépendance sans la supprimer : l’obligation contractuelle de signalement imposée aux tiers, et une veille active qui ne se contente pas d’attendre les avis entrants. Le demandeur ne prétend pas ramener ce risque à zéro ; il le considère comme l’une des raisons pour lesquelles les mesures de protection ne reposent jamais sur un seul contrôle.

Notes de rédaction — à retirer avant le dépôt

Point	À faire
Cibles de la section 2	Les cibles et les seuils sont proposés. Les arrêter avant le dépôt, en particulier le 99,5 % de disponibilité, la reprise en 4 heures ouvrables et la détection en 60 minutes, qui engagent le demandeur devant la Banque.
Seconde personne habilitée	La double approbation des lots suppose une seconde personne. La nommer, la former et documenter sa suppléance ; le cadre en fait une condition d'activation de la fonction de paiement.
Ressource indépendante	Retenir la ressource chargée de l'examen indépendant de l'article 10 et convenir de son cycle. Elle doit être distincte de l'agent de conformité en matière de recyclage des produits de la criminalité.
Provision d'exploitation	Chiffrer les douze mois de charges fixes mentionnés à la section 3 et les rattacher à la projection de trésorerie jointe à la section 12.
Tiers à nommer	Institution financière parraine, partenaire de virement, hébergeur et fournisseur de vérification demeurent génériques, comme à la question 6.1. Y substituer les dénominations retenues, et joindre les ententes à la section 13.
Conseil d'administration	Le Règlement distingue l'approbation par le cadre dirigeant de celle du conseil. Confirmer auprès du conseiller juridique la forme que prend cette double approbation dans une société à administrateur unique, et consigner les deux approbations séparément.
Systèmes désignés	Vérifier, au moment du dépôt, la liste des systèmes de compensation et de règlement désignés tenue par la Banque du Canada, et nommer en conséquence les chambres de compensation visées à la section 9 — en particulier le statut du système de virement Interac.
Spécification du fichier 005	La note 5 donne la spécification usuelle — enregistrement de 1 464 caractères, en-tête de 24 caractères et six segments de 240. Confirmer la version de la norme en vigueur auprès de Paiements Canada et, surtout, le guide de mise en œuvre propre à l'institution parraine retenue, qui peut imposer ses propres contraintes.
Renseignements personnels	Faire confirmer par le conseiller juridique quelles obligations de signalement en matière de renseignements personnels s'appliquent en parallèle de l'article 18 de la Loi, et les nommer aux sections 8 et 9 et à la note 4 plutôt que d'y renvoyer génériquement.
Portail de notification	Vérifier les modalités d'accès au portail de la Banque du Canada et le format exact de l'avis d'incident au moment du dépôt.